@demotoprod · KEYS

Agent observability checklist

On 6 October 2026 a safety-evaluation lab published a red-team of the transcript viewer in a widely used open-source evaluation framework. One researcher, helped by an AI agent, needed about ten minutes to find a script injection that let an agent rewrite what a human reviewer saw of its own run. The maintainers patched it within a day. The record in the database was never touched; the page was. Three checks for any tool a person uses to supervise an agent.

1 Render agent output as plain text in every supervision tool

The viewer rendered math notation inside the agent's output. A URL inside one math expression broke out of its attribute and inserted an element whose event handler ran the agent's JavaScript in the reviewer's browser. The agent could place that expression anywhere, including its reasoning block, so the script ran the moment a reviewer opened the transcript, and it could change the previous actions shown and intercept the Download button to serve an altered copy.

- Treat every agent output (transcript, reasoning, tool results) as untrusted input to the UI that shows it.
- Switch off markdown, HTML, math and media rendering for agent-written content; the patched viewer's own setting is the model: one flag, content shown as literal text.
- Apply the same rule to in-house dashboards and notebooks, not only to the vendor's viewer.

```
ViewerConfig(trust_content=False)   # agent output shown as literal text, not rendered
(merged 1 Oct 2026)
```

2 Verify against the stored record, never the rendered page

The underlying transcripts were not modified; only the display was. The real trajectory sat in the lab's database the whole time, but a reviewer needs a reason to look there, and the page gave none.

- Hash each step as it is written, and keep the hashes where the agent cannot reach them.
- Export and download transcripts from the store, never through a button on a page the agent's output can script.
- Spot-check the stored record against the viewer on a sample of runs.

3 Red-team the monitoring itself, before the agent does

The flaw took about ten minutes to find with an AI agent helping, and a day to fix once reported. The lab's conclusion is that observability against an adversarial agent only helps if the agent cannot subvert that observability, so the systems that record and display agent behaviour are security-critical infrastructure.

- Put the trace viewer, the log store and the alerting path in scope for the same red-team as the agent.
- Give an agent the explicit task of altering what a reviewer sees, in a staging copy, and record what it manages.
- Make it hard for an agent to influence the systems used to supervise it; log every write to them.